PERSONA 3 · Sistema web (OWASP ZAP)

Persona 3 — Auditoria web con OWASP ZAP

Tres entregas: (a) trazabilidad del trafico por el proxy SIN modificar, (b) ≥ 3 vulnerabilidades del OWASP Top 10 explotadas, (c) plan de mitigacion.

Que codigo usar

Fichero / herramienta	Para que
`web/payloads/sqli.txt`	Diccionario de inyeccion SQL para el Fuzzer
`web/payloads/xss.txt`	Diccionario de XSS para el Fuzzer
DVWA (Docker) y OWASP ZAP	Externos: se instalan aparte (ver Paso 0 y 1)

Que es esto

DAST = probar la web desde fuera, como un atacante, sin ver el codigo. **OWASP ZAP** se pone entre el navegador y la web (proxy): ve, registra y puede modificar cada peticion. Para leer HTTPS genera certificados al vuelo con su propia CA, por eso hay que **importar su certificado raiz** en el navegador. **Fuzzing** = repetir una peticion con muchas cadenas de ataque de un diccionario.

> Usa OWASP Top 10 **2021** (la "2023" del PDF es la de APIs). Dilo en el informe.

Paso 0 — Montar la web de pruebas (DVWA)

Nunca se ataca una web real. Usamos **DVWA**, que trae una pagina por vulnerabilidad y niveles de seguridad (ideales para el "antes/despues" de la mitigacion):

```
docker run --rm -it -p 8080:80 vulnerables/web-dvwa
# Navegador: http://localhost:8080  (admin / password, luego "Create / Reset Database")
```

Paso 1 — ZAP como proxy

1. Instala ZAP (`zaproxy.org/download` ; necesita Java, ya esta en el equipo).
2. Options → Network → Local Servers/Proxies: direccion `localhost` , puerto **8081**.
3. Options → Dynamic SSL Certificates → **Save** el certificado raiz.
4. Importalo en Firefox: Certificate Manager → Authorities → Import → "Trust this CA to identify websites".
5. Apunta el navegador al proxy `localhost:8081` (lo mas facil: boton **"Manual Explore"** de ZAP).

Paso 2 — Entrega (a): trazabilidad SIN modificar

Navega por DVWA y haz un login. En la pestana **History** veras cada peticion/respuesta. Abre un login POST y ensena cabeceras y parametros (usuario/contrasena). Aqui **no se modifica nada**: solo demuestras que ves el trafico. Captura o exporta esas peticiones.

Paso 3 — Entrega (b): 3+ vulnerabilidades (en DVWA)

Vulnerabilidad	OWASP 2021	Como	Que demuestra
SQL Injection	A03	Pagina "SQL Injection": Fuzzer sobre `id` con `jbrofuzz → SQL Injection`	Sacar usuarios/hashes con `1' OR '1'='1`
XSS reflejado	A03	Pagina "XSS (Reflected)": `<script>alert(1)</script>`	El navegador ejecuta tu codigo
XSS almacenado	A03	Pagina "XSS (Stored)": guardar el script	Ataca a quien abra la pagina

Con estas tres cubres las obligatorias. *Path Traversal* (File Inclusion, `?page=../../../../etc/passwd`) y *CSRF* suben nota si sobra tiempo.

Como fuzzear

1. Boton derecho sobre una peticion con parametros → **Fuzz**.
2. Selecciona el parametro → Payloads → Add → File Fuzzer → `jbrofuzz → SQL Injection` (o el fichero `web/payloads/sqli.txt`).
3. Start Fuzzer. Las filas marcadas **Reflected** (Status) o **Found** (Reason) son las interesantes.

Paso 4 — Entrega (c): mitigacion

Sube el nivel de DVWA (DVWA Security → "High" / "Impossible"), repite el ataque y ensena que **ya no funciona**. Explica por que: consultas parametrizadas, validacion de entrada, escape de salida, token CSRF.

Que entregar

- Session de ZAP o export de las peticiones; captura del certificado raiz importado; informe HTML de ZAP (Report → Generate HTML Report). Todo a `evidencias/web/`.
- Los payloads usados (`web/payloads/`).
- En el informe: la demo de trazabilidad, una ficha por vulnerabilidad (peticion, payload, resultado, captura) y el plan de mitigacion con el "antes/despues" del nivel de DVWA.